



Defense-in-Depth ICS Network Security Lab

Network Segmentation, Firewall Enforcement,
Intrusion Prevention and Centralized Monitoring

Valentin Ochioiu
Network Security Student

Folkuniversitetet, Gothenburg
4 April 2026

Inspired by the security lessons of the 2010 Stuxnet attack

This project was designed around an industrial control system security scenario inspired by the **2010 Stuxnet attack**.

The goal was not to recreate Stuxnet itself, but to explore how layered network security controls can reduce **lateral movement toward critical industrial systems**.

Security questions explored

- ▶ How can user networks be isolated from ICS systems?
- ▶ How can access to a PLC be tightly controlled?
- ▶ How can suspicious SMB traffic be detected and blocked?
- ▶ How can security events be monitored centrally?

Project Focus

ICS / OT Security

Network Segmentation

Lateral Movement Reduction

Firewall Enforcement

Intrusion Prevention

Centralized Monitoring

Protecting critical systems through layered security controls

The objective was to design and secure a segmented industrial network using a **defense-in-depth architecture**.

The environment was designed to reduce lateral movement from a compromised user system toward critical ICS assets.

Primary goals

- ▶ Reduce lateral movement
- ▶ Protect the controller and PLC networks
- ▶ Restrict unnecessary communication
- ▶ Detect suspicious network and host activity

01 — Segment

Separate systems by role and trust.

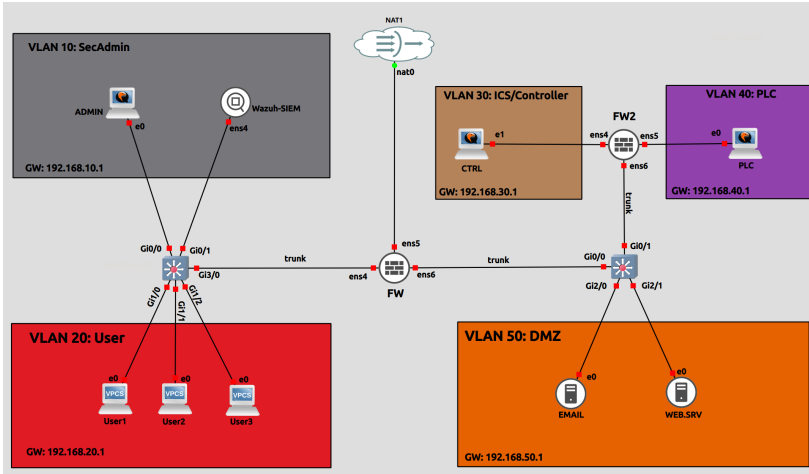
02 — Enforce

Restrict traffic using least privilege.

03 — Monitor

Detect and investigate abnormal activity.

Network Topology



Security Zones

VLAN 10

SecAdmin

VLAN 20

User

VLAN 30

ICS / Controller

VLAN 40

PLC

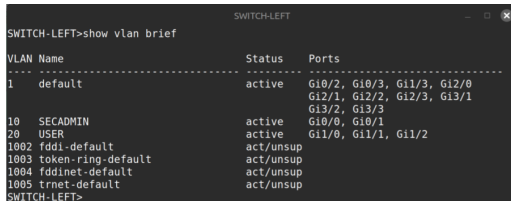
VLAN 50

DMZ

Actual GNS3 topology
used for the lab.

VLAN Configuration

Left-side switch



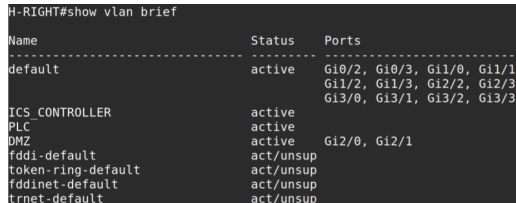
```
SWITCH-LEFT>show vlan brief
```

VLAN	Name	Status	Ports
1	default	active	Gi0/2, Gi0/3, Gi1/3, Gi2/0, Gi2/1, Gi2/2, Gi2/3, Gi3/1, Gi3/2, Gi3/3
10	SECADMIN	active	Gi0/0, Gi0/1
20	USER	active	Gi1/0, Gi1/1, Gi1/2
1002	fddi-default	act/unsup	
1003	token-ring-default	act/unsup	
1004	fddinet-default	act/unsup	
1005	trnet-default	act/unsup	

SWITCH-LEFT>

Example show vlan brief output verifying the SecAdmin and User VLAN configuration.

Right-side switch



```
H-RIGHT#show vlan brief
```

Name	Status	Ports
default	active	Gi0/2, Gi0/3, Gi1/0, Gi1/1, Gi1/2, Gi1/3, Gi2/2, Gi2/3, Gi3/0, Gi3/1, Gi3/2, Gi3/3
ICS_CONTROLLER	active	
PLC	active	
DMZ	active	Gi2/0, Gi2/1
fddi-default	act/unsup	
token-ring-default	act/unsup	
fddinet-default	act/unsup	
trnet-default	act/unsup	

Example show vlan brief output verifying the ICS Controller, PLC and DMZ VLANs.

Additional hardening: The User VLAN was treated as low trust, access toward critical systems was restricted, and unused switch ports were disabled to reduce the attack surface.

802.1Q Trunk Configuration

Left-side trunk

```
SWITCH-LEFT
SWITCH-LEFT>show interfaces trunk

Port      Mode      Encapsulation  Status      Native vlan
Gi3/0     on        802.1q         trunking    1

Port      Vlans allowed on trunk
Gi3/0     10,20

Port      Vlans allowed and active in management domain
Gi3/0     10,20

Port      Vlans in spanning tree forwarding state and not pruned
Gi3/0     10,20
SWITCH-LEFT>
```

Example show interfaces trunk output. The trunk carries the VLANs required by the SecAdmin and User segments.

Right-side trunk

```
SWITCH-RIGHT#show interfaces trunk

Port      Mode      Encapsulation  Status      Native vlan
Gi0/0     on        802.1q         trunking    1
Gi0/1     on        802.1q         trunking    1

Port      Vlans allowed on trunk
Gi0/0     30,40,50
Gi0/1     30,40

Port      Vlans allowed and active in management domain
Gi0/0     30,40,50
Gi0/1     30,40

Port      Vlans in spanning tree forwarding state and not pruned
Gi0/0     30,40,50
Gi0/1     30,40
```

The right-side trunk carries the ICS Controller, PLC and DMZ VLANs toward the firewall infrastructure.

802.1Q trunks allow multiple VLANs to share physical links while preserving logical separation.

Defense-in-Depth Architecture



Layer 2

VLANs separate systems by role and trust level.

Enforcement

nftables controls zone access while Suricata inspects and blocks malicious traffic.

Monitoring

Wazuh centralizes firewall, Suricata and host security events.

Multiple independent security layers reduce the impact of a single compromise.

Firewall Security Model

FW1 — Main Zone Firewall

- ▶ Controls SecAdmin, User and DMZ traffic
- ▶ Default-deny policy
- ▶ Only required services are permitted
- ▶ VLAN 20 is restricted from administrative and ICS networks
- ▶ Required Wazuh traffic is explicitly allowed
- ▶ Denied traffic is logged

FW2 — Critical Asset Firewall

- ▶ Separates the Controller and PLC networks
- ▶ Required CTRL-to-PLC communication only
- ▶ PLC cannot initiate new connections toward CTRL
- ▶ Established return traffic is allowed
- ▶ Provides an additional security boundary around the PLC

Policy principle: deny unnecessary traffic and explicitly permit only required communication.

Firewall Configuration — Input Protection

Example configuration

An example of the firewall configuration is shown here.

The FW1 input chain demonstrates:

- ▶ Default-drop policy
- ▶ Stateful filtering
- ▶ Invalid-state filtering
- ▶ ICMP rate limiting
- ▶ Admin-only SSH access
- ▶ Firewall logging
- ▶ NFQUEUE forwarding to Suricata

```
debian@FIREWALL:~$ sudo cat /etc/nftables.conf
flush ruleset
table inet filter {
# ZONER
define VLAN10 = 192.168.10.0/24
define VLAN20 = 192.168.20.0/24
define VLAN30 = 192.168.30.0/24
define VLAN50 = 192.168.50.0/24
# HOSTS
define ADMIN_HOST = 192.168.10.10
define WAZUH_MGR = 192.168.10.20
define CTRL_HOST = 192.168.30.10
define FW2_MGMT = 192.168.30.200
define EMAIL_HOST = 192.168.50.10
define WEB_HOST = 192.168.50.20

chain input {
type filter hook input priority 0;
policy drop;

# All trafik går genom Suricata/IPS för DPI
meta mark & 0x1 == 0 queue num 0 bypass

iifname "lo" accept
ct state established,related accept
ct state invalid drop

# ICMP för felsökning
ip protocol icmp icmp type echo-request limit rate 2/second burst 5 packets accept

# SSH till FW1 endast från Admin
ip saddr $ADMIN_HOST tcp dport 22 ct state new limit rate 5/minute accept

# Logga och drop allt annat
limit rate 2/minute burst 5 packets log prefix "FW1 INPUT DROP: " drop
}
```

Firewall Configuration — Forwarding Policy

```
chain forward {
    type filter hook forward priority 0;
    policy drop;

    # All trafik går genom Suricata/IPS för DPI
    meta mark & 0x1 == 0 queue num 0 bypass

    ct state established,related accept
    ct state invalid drop

    # Wazuh agent trafik från CTRL till Wazuh Manager
    ip saddr $CTRL_HOST ip daddr $WAZUH_MGR tcp dport { 1514, 1515 } accept

    # Explicit allow regler

    # Admin till FW2 management
    ip saddr $ADMIN_HOST ip daddr $FW2_MGMT tcp dport 22 accept

    # Admin till DMZ för administration
    ip saddr $ADMIN_HOST ip daddr $VLAN50 tcp dport { 22, 80, 443 } accept

    # User till DMZ tjänster
    ip saddr $VLAN20 ip daddr $EMAIL_HOST tcp dport 25 accept
    ip saddr $VLAN20 ip daddr $WEB_HOST tcp dport { 80, 443 } accept

    # Segmentering

    # VLAN20 isolation
    ip saddr $VLAN20 ip daddr { $VLAN10, $VLAN30 } log prefix "VLAN20 DROP: " drop

    # VLAN10 har ingen direkt åtkomst till CTRL-zonen, förutom FW2 management
    ip saddr $VLAN10 ip daddr $CTRL_HOST log prefix "VLAN10 TO CTRL DROP: " drop
    ip saddr $VLAN10 ip daddr $VLAN30 log prefix "VLAN10 TO VLAN30 DROP: " drop

    # DMZ får inte nå interna zoner
    ip saddr $VLAN50 ip daddr { $VLAN10, $VLAN20, $VLAN30 } log prefix "VLAN50 DROP: " drop
```

Example forwarding rules

This section controls traffic crossing between the security zones.

Examples include:

- ▶ Controller-to-Wazuh traffic
- ▶ Admin management access
- ▶ User access to selected DMZ services
- ▶ VLAN 20 isolation

Firewall Configuration — Final Enforcement Rules

```
# Blockera åtkomst till VLAN10 om inte tillåtet
ip daddr $VLAN10 log prefix "TO VLAN10 DROP: " drop

# Blockera åtkomst till VLAN30 om inte tillåtet
ip daddr $VLAN30 log prefix "TO VLAN30 DROP: " drop

# Blockera åtkomst till VLAN50 om inte tillåtet
ip daddr $VLAN50 log prefix "TO VLAN50 DROP: " drop

# Logga och drop allt annat
limit rate 2/minute burst 5 packets log prefix "FW1 FORWARD DROP: " drop
}
chain output {
    type filter hook output priority 0;
    policy accept;
}
}
debian@FIREWALL:~$
```

Default enforcement

The final forwarding rules block traffic toward protected zones when no earlier allow rule has matched.

The configuration also:

- ▶ Logs rejected traffic
- ▶ Uses identifiable log prefixes
- ▶ Applies a final default-drop rule

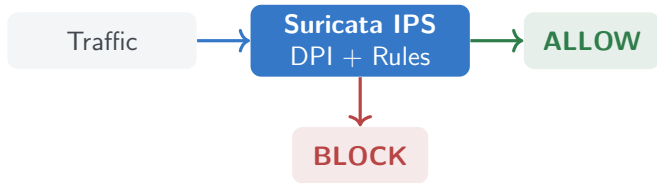
Intrusion Prevention with Suricata

Inline IPS inspection

Suricata was integrated with nftables through **NFQUEUE** and operated as an inline IPS.

Traffic could therefore be inspected before being permitted through the firewall.

- ▶ Deep Packet Inspection
- ▶ Stateful stream analysis
- ▶ Custom signatures
- ▶ Real-time blocking



Custom IPS rules were created to test detection and blocking of suspicious SMB-related activity.

Custom Suricata IPS Rules

Examples of custom Suricata rules used during the lab

The rules target selected SMB-related payload patterns and actively block matching traffic.

```
# Blockerar .NET relaterade payloads via mscorere.dll vilket tyder på managed Windows applikationer.  
drop tcp any any -> any 445 (msg:"STUXNET SMB .NET payload"; flow:to_server,established; file_data; content:"mscorlib"; nocase; sid:1000105; rev:1;)
```

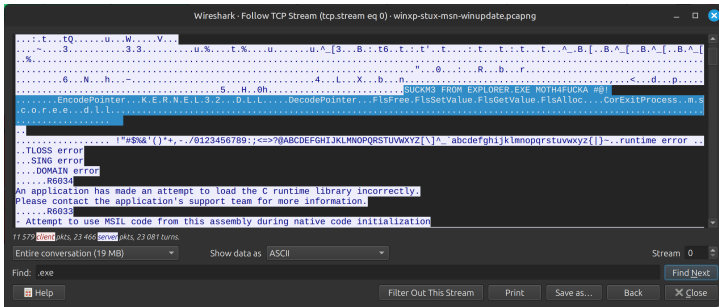
Custom rule designed to drop SMB traffic containing the .NET runtime component `mscorlib.dll`.

```
# Blockerar överföring av exekverbara filer via SMB.  
drop tcp any any -> any 445 (msg:"STUXNET SMB EXE transfer"; flow:to_server,established; file_data; content:".exe"; nocase; sid:1000103; rev:2;)
```

Custom rule designed to drop SMB traffic matching executable-file transfer patterns.

Because Suricata operated in inline IPS mode, the drop action allowed matching traffic to be blocked rather than only generating an alert.

Payload Inspection — Wireshark Evidence



Important limitation

Seeing the indicator in a TCP stream does not guarantee that every variation of the traffic will trigger the IPS rule.

Matching depends on payload structure, encoding, encryption and rule context.

Payload visibility

Wireshark was used to inspect a reconstructed TCP stream.

The payload contains the visible string:

`mscoree.dll`

This is an example of the type of payload indicator targeted by one of the custom Suricata rules.

The screenshot demonstrates why payload-aware inspection can provide more context than basic packet filtering alone.

Signature Detection — Strengths and Limitations

What the rules demonstrate

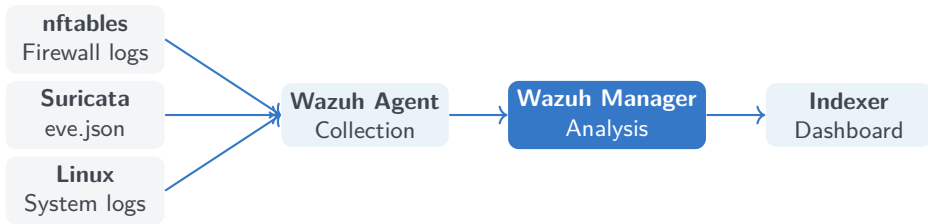
- ▶ Inspection of SMB-related payload data
- ▶ Detection of selected content indicators
- ▶ Inline enforcement using drop
- ▶ nftables and Suricata integration through NFQUEUE
- ▶ Practical Deep Packet Inspection

Limitations

- ▶ Signatures target specific payload patterns
- ▶ Different structures may avoid a match
- ▶ Encoding or compression may change visible content
- ▶ Encryption can prevent payload inspection
- ▶ False positives require tuning and validation

Key point: One exact content signature should not be treated as complete protection against an entire malware family or attack technique.

Centralized Monitoring with Wazuh



Collected security information

The Wazuh agent was configured through `ossec.conf` to collect:

- ▶ Firewall events
- ▶ Suricata IPS alerts
- ▶ Authentication activity
- ▶ Host-level system events

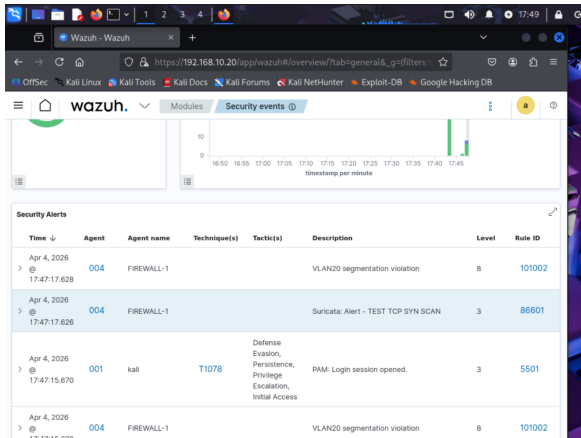
Log integration decision

Both `fast.log` and `eve.json` were tested during the integration.

`fast.log` produced duplicated and less detailed events in the dashboard.

Structured `eve.json` logging was therefore used for the final Suricata integration.

Wazuh — Segmentation and Scan Detection



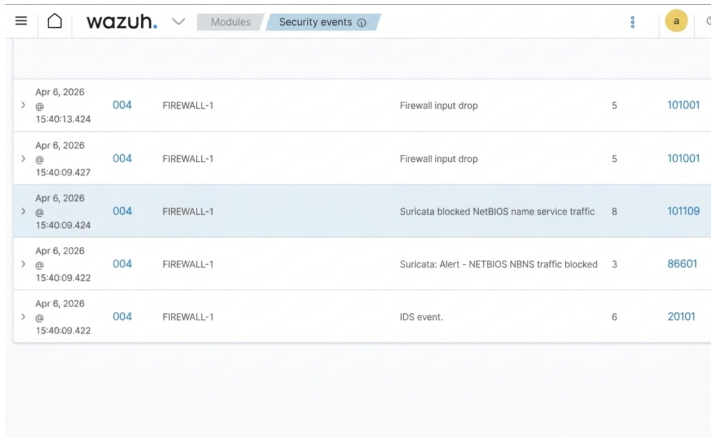
Correlated events

The dashboard shows multiple events generated during testing.

- ▶ VLAN 20 segmentation violation
- ▶ Suricata TCP SYN scan alert
- ▶ PAM login session

Network and host activity can be reviewed together in a centralized view.

Wazuh — Suricata Detection and Active Blocking



wazuh. Modules Security events ⓘ						
> @	Apr 6, 2026 15:40:13.424	004	FIREWALL-1	Firewall input drop	5	101001
> @	Apr 6, 2026 15:40:09.427	004	FIREWALL-1	Firewall input drop	5	101001
> @	Apr 6, 2026 15:40:09.424	004	FIREWALL-1	Suricata blocked NetBIOS name service traffic	8	101109
> @	Apr 6, 2026 15:40:09.422	004	FIREWALL-1	Suricata: Alert - NETBIOS NBNS traffic blocked	3	86601
> @	Apr 6, 2026 15:40:09.422	004	FIREWALL-1	IDS event.	6	20101

Verified blocking

The event sequence was generated during a NetBIOS-related traffic test.

Visible events include:

- ▶ IDS event
- ▶ Suricata NetBIOS alert
- ▶ Suricata block event
- ▶ Firewall input drop

The result confirms that traffic was both **detected** and **actively blocked**.

Validation and Results

Security controls were tested against multiple types of activity

Test	Control	Expected Result	Observed Result
User VLAN segmentation	nftables	Traffic blocked and logged	Segmentation violation visible in Wazuh
TCP SYN scan	Suricata	Suspicious scan detected	Suricata SYN scan alert generated
NetBIOS-related traffic	Suricata IPS	Traffic detected and blocked	Alert and blocking event visible in Wazuh
Host login activity	Wazuh Agent	Host event collected	PAM login event visible in dashboard

The tests verified that the architecture could **prevent, detect and centrally record** different types of network and host activity.

Limitations and Future Improvements

Current limitations

- ▶ Custom IPS signatures target specific payload indicators
- ▶ Encrypted traffic reduces payload visibility
- ▶ False-positive and false-negative rates were not formally measured
- ▶ Inline IPS performance and latency were not benchmarked
- ▶ No firewall or SIEM redundancy was implemented
- ▶ PLC-specific industrial protocol inspection was outside the lab scope

Future improvements

- ▶ Expand and tune Suricata detection rules
- ▶ Test additional lateral-movement techniques
- ▶ Measure false positives and detection coverage
- ▶ Benchmark IPS throughput and latency
- ▶ Add redundant firewall and monitoring components
- ▶ Add protocol-aware monitoring for industrial traffic

The lab demonstrates security architecture and control integration, but it is not intended to represent a complete production ICS security deployment.

A layered security architecture for protecting critical ICS assets

Implemented

- ▶ VLAN-based network segmentation
- ▶ nftables firewalling with a default-deny approach
- ▶ Suricata inline IPS through NFQUEUE
- ▶ Wazuh SIEM for centralized monitoring

Validated

- ▶ VLAN isolation and restricted inter-zone traffic
- ▶ Network scan detection
- ▶ Firewall logging and segmentation violations
- ▶ Suricata alerting and active blocking

Result

The final environment combined **segmentation, enforcement and centralized monitoring** to reduce the risk of lateral movement toward critical ICS systems.

The lab demonstrated how multiple security controls can work together to protect critical industrial assets.